

hacking réseau

Petite histoire du hacking

Le terme de « hacking » en lien avec la technologie est apparu dans les années cinquante au MIT, et était utilisé par les membres du **Tech Model Railroad Club** pour désigner un **processus permettant de résoudre de façon créative et innovante un problème technique**.

Dans les années 60, ces étudiants sont passés de l'étude des trains aux ordinateurs, et ont mis en œuvre toute leur inventivité pour exploiter au maximum le potentiel de cette nouvelle technologie.

Dans les années 70, d'autres se sont attaqués de la même manière au réseau téléphonique. Appelés « phreakers », ou « phone freaks », ces passionnés passaient des heures à explorer le réseau téléphonique pour en comprendre les interconnexions, avant d'innover avec leurs propres exploits. Ils concevaient des appareils artisanaux appelés « blue boxes », pour les assister dans ces aventures. Avant de connaître le succès avec Apple, Steve Wozniak et Steve Jobs faisaient partie de cette communauté de passionnés du phreaking.

Dans les années 80, le phénomène du hacking a explosé. Désormais, tout utilisateur d'un ordinateur pouvait faire partie de la communauté des hackers. Mais il était inévitable qu'avec le nombre croissant d'utilisateurs se découvrant des talents de hacker, certains utilisent ces talents à des fins criminelles.

C'est donc en 1986 que la première loi anti-cybercrime a été votée : le Computer Fraud and Abuse Act aux États-Unis.

Sous-culture des hackers

Dans son expression la plus positive, la culture des hackers met en avant la créativité et les compétences dans le domaine technologique. Les hackers de tous les âges cherchent à expérimenter et à explorer, à envisager les technologies sous différents angles et à répondre à l'éternelle question « **Et si... ?** ».

Comme l'alpiniste George Mallory qui expliquait vouloir conquérir l'Everest « Parce qu'il est là », les hackers cherchent eux aussi à faire étalage de leurs compétences en résolvant des problèmes d'ordre technologique. Et lorsque vous entendez autour de vous les gens parler des « **life hacks** », ces astuces qui simplifient le quotidien, ils utilisent bien le terme « hack » dans le même esprit.

Même si à l'origine, le hacking n'a rien de malveillant, ce désir peut parfois entraîner les mordus d'informatique dans des eaux plus troubles. Les grandes entreprises ont tendance à ne pas apprécier que l'on contourne par effraction leurs systèmes de sécurité sans leur autorisation, et elles ont souvent recours à des poursuites judiciaires pour faire un exemple des hackers qui sont allés trop loin.

Le hacking est-il illégal ?

Le fait que le hacking constitue ou non un cybercrime ne dépend que d'une chose : le consentement. Les pirates éthiques que sont les white hat hackers obtiennent une autorisation avant de s'attaquer aux systèmes et ils sont obligés de signaler toutes les vulnérabilités qu'ils rencontrent. Hors de ce contexte, le hacking dans le domaine de la sécurité est une activité illégale.

Les hackers criminels, ou pirates, qui agissent sans consentement enfreignent la loi. Personne ne va vous autoriser à un acte de hacking si vous expliquez avant d'agir que vous cherchez à voler de l'argent ou des secrets professionnels. Les pirates que sont les black hat hackers travaillent donc dans l'ombre. Même le grey hat hacking peut être dangereux si la cible décide de porter plainte contre vous une fois que vous avez révélé ce que vous avez fait.

Il va sans dire que si vous êtes victime d'un piratage lié à la sécurité, il est tout à fait illégal. Si cela vous arrive, signalez immédiatement l'arnaque ou la tentative de piratage. Vous pouvez limiter les dégâts de votre côté et aussi éviter que le pirate fasse d'autres victimes.

En fonction de leurs motivations, les hackers peuvent être des « black hat hackers » (malveillants, ou pirates), des « white hat hackers » (bienveillants, ou « pirates éthiques ») ou bien gris (entre les deux). Voyons ce qui les caractérise et comment les distinguer.

Les pirates informatiques

Le hacker malveillant, ou pirate informatique correspond au profil du cybercriminel décrit plus haut. Il contourne les systèmes de cybersécurité pour accéder de façon illégale aux ordinateurs ou aux réseaux. S'il découvre une faille de sécurité, il va soit l'exploiter pour son propre compte, soit la faire connaître aux autres hackers, en général en échange d'une somme d'argent.

La plupart du temps, l'objectif du black hat hacker est de gagner de l'argent, en s'en emparant directement ou en le volant, en vendant des informations piratées ou en essayant d'extorquer de l'argent. Mais la plupart du temps, il cherche juste à créer le plus de problèmes possible.

Pirates éthiques

Les white hat hackers, ou pirates éthiques sont l'opposé des black hats. Ils sont tout aussi compétents, mais plutôt que d'appliquer ces compétences dans un but criminel, ils cherchent à aider les entreprises à renforcer leurs systèmes de sécurité informatique. Le white hat hacker essaie intentionnellement d'entrer par effraction dans un système, avec l'autorisation de son propriétaire, afin d'en identifier les points faibles pour pouvoir y remédier. Ce type de travail est appelé « piratage éthique ».

Nombreux sont les white hat hackers à être employés par une grande entreprise dans le cadre de sa politique de cybersécurité. D'autres proposent leurs services de test de la sécurité informatique en tant que consultants ou indépendants. Ces services peuvent aller plus loin que la simple entrée dans le système de cybersécurité et peuvent par exemple impliquer de tester les employés par des campagnes de phishing (hameçonnage) visant à renforcer le niveau de sécurité des informations d'identification.

Les « grey hat hackers »

Entre ces deux profils opposés se trouvent ceux que l'on appelle les « grey hat hackers ». Ils ne sont pas aussi altruistes que les pirates éthiques, mais ils ne sont pas pour autant de véritables cybercriminels. Alors que les pirates éthiques disposent d'une autorisation pour tester les vulnérabilités des systèmes, les grey hat hackers se passent de cette permission.

Certains d'entre eux se comportent comme des mercenaires : après avoir découvert une faille de sécurité, ils contactent l'entreprise concernée pour lui proposer leurs services contre récompense. D'autres agissent dans le but de forcer une entreprise qui se montre réticente à résoudre une vulnérabilité connue. Un exemple notable de grey hat hacking s'est produit en 2013 et a forcé Facebook à reconnaître une faille de sécurité et à la réparer après avoir ignoré les avertissements du hacker.

Appareils les plus vulnérables face au hacking

Parmi tous les appareils qui nous entourent à la maison ou au bureau, certains sont des cibles plus faciles que d'autres. Bien que votre iPhone soit extrêmement résistant, ce n'est pas le cas de tous les appareils électroniques grand public. Voici une petite liste des appareils les plus à risque :

Appareils intelligents : de nombreux appareils de l'Internet des objets ne disposent pas des mêmes protections de sécurité que celles intégrées dans les ordinateurs et les appareils mobiles. Si un hacker récupère vos données lors d'une fuite, il peut exploiter tout ce qu'il trouve pour s'introduire dans votre réseau intelligent et passer d'un appareil à un autre.

Routeurs : vous n'imaginez même pas combien de personnes n'ont jamais modifié les informations d'identification par défaut de leur routeur. Vous en faites peut-être même partie. Les hackers savent quels appareils sont fournis avec quelles informations d'identification et ils peuvent tester les réseaux Wi-Fi pour savoir si ces informations sont toujours valables. Les routeurs et les appareils intelligents sont particulièrement vulnérables aux malwares de type botnet, qui peuvent les inclure dans une attaque par déni de service distribué (DDoS).

Appareils les plus vulnérables face au hacking

Webcams : si vous utilisez encore une webcam autonome, elle présente les mêmes vulnérabilités que n'importe quel autre objet connecté. Les utilisateurs d'ordinateurs portables sont également exposés aux rootkits, un type de malware permettant aux hackers d'accéder à tout moment à un appareil, y compris à la caméra orientée vers l'utilisateur. Il peut donc être intéressant de coller un morceau d'adhésif opaque sur cette caméra.

E-mail : il ne s'agit pas d'un appareil, mais les e-mails sont une cible privilégiée des hackers. Les mots de passe fuient régulièrement lors de vols de données, et si vous utilisez le même mot de passe pour votre e-mail et vos autres services, vous laissez la porte grande ouverte aux hackers.

Téléphones débridés : les appareils iOS, et dans une moindre mesure les appareils Android, sont extrêmement résistants face au hacking. Si vous avez débridé votre appareil (c'est-à-dire supprimé les mesures de sécurité intégrées par le fabricant), vous serez plus vulnérable au hacking, à moins que vous ne connaissiez bien les contre-mesures à adopter.

Pour éviter que des hackers s'introduisent sur votre réseau ou sur l'un de vos appareils, utilisez un outil de cybersécurité robuste, comme Avast One. Avast applique six couches de protection, plus une intelligence artificielle basée dans le cloud pour bloquer 1,5 milliard d'attaques de malwares tous les mois. Il détecte les vulnérabilités de votre Wi-Fi domestique, vous alerte sur les paramètres non sécurisés et les mots de passe faibles et vous protège des tentatives de phishing et des virus, le tout gratuitement.

« Mon compte a été piraté ! » À chaque problème sur les réseaux sociaux, c'est la ligne de défense favorite des célébrités affectées. Si vous ne prêtez pas attention à vos mots de passe, un pirate peut facilement prendre le contrôle d'un de vos comptes. il peut alors publier ce qu'il veut sous votre nom, accéder à votre contenu privé et entrer en contact avec vos amis.

Vous voulez vérifier si le mot de passe de vos comptes de réseaux sociaux ou d'e-mail a fuité ? Consultez notre outil gratuit HackCheck pour rechercher les mots de passe divulgués.

Quel est le risque de piratage sur les réseaux sociaux ? Recherchez par exemple « hacking Facebook » sur Google, comme je l'ai fait pour rechercher des actualités sur ce sujet en préparant cet article. Au lieu de trouver des informations, vous tombez sur une liste d'outils de piratage pour Facebook. Bien entendu, nous vous déconseillons de faire cette expérience ou de consulter les liens mentionnés dans cette recherche.

Le piratage de Twitter et d'Instagram est également une activité assez répandue. La page d'aide de Twitter pour les comptes piratés suggère en premier recours de réinitialiser votre mot de passe, ce qui renvoie à l'idée d'utiliser un mot de passe différent pour chaque service que vous utilisez. En effet, si le pirate récupère un mot de passe, il ne pourra se connecter qu'au compte correspondant.

Pour sécuriser son réseau, il est important de bien le connaître.

Il existe la règle des cinq P pour découper les phases d'une agression informatique :

- Prospection (*Probe*) : pour obtenir des informations sur le réseau de la victime ;
- Pénétration : s'introduire dans le système de la victime ;
- Persistance : être capable d'y retourner ou d'y rester ;
- Propagation : se diffuser sur les autres systèmes de la victime ;
- Paralysie : l'action effective, déclenchement du ransomware ou autre.

Il n'est pas clair de déterminer la légalité d'une exploration du réseau. Une organisation peut considérer que l'exploration que vous avez tenté de faire est une tentative d'agression et prendre des contre-mesures contre l'organisation d'où cette exploration est issue. Pour éviter cela, de nombreuses organisations peuvent détecter les tentatives générées depuis leur domaine et agir contre la source. Il est donc beaucoup plus prudent d'effectuer ces actions sur votre propre réseau ou de demander une autorisation écrite.

Outils complémentaires

tshark, outil qui permet d'analyser les paquets vus par une carte réseau.
C'est un outil en ligne de commandes, la version texte de Wireshark.

Tcpdump. Nous allons l'utiliser pour comprendre comment nmap agit.

Netcat, le couteau suisse pour TCP/IP, permet de simuler des clients ou des serveurs et bien plus encore.
il pourra être utilisé pour confirmer (ou infirmer) ou préciser les détections de nmap.

Arpwatch

Rappel succinct TCP/IP

Il y a deux types de trames : les trames *unicast* et *broadcast* (diffusion).

Les trames broadcast sont envoyées à tous.

Les trames unicast sont envoyées à des destinataires uniques.

Les commutateurs Ethernet moderne n'envoient les trames que vers le destinataire prévu.

Un hôte ne peut donc étudier que les paquets de broadcast et les paquets qui lui sont destinés.

Deux façons de contourner le problème, c'est soit de se faire passer pour le routeur, soit de passer le commutateur en mode dégradé pour qu'il arrête le filtrage et diffuse toutes les trames à tous les hôtes.

Pour obtenir les adresses Ethernet des voisins dont on connaît l'adresse IP, il faut utiliser le protocole ARP.

Rappel succin ARP

Quand un ordinateur souhaite envoyer un paquet IP à un autre ordinateur, il commence par déterminer si le destinataire est sur le même réseau que lui ou s'il doit passer par un routeur.

- Dans le premier cas, il enverra une trame Ethernet au destinataire ;
- Dans le second, au routeur.

C'est le protocole ARP qui est utilisé pour faire la correspondance adresse IP et adresse MAC

La capture tshark montre l'échange.

```
18:66:da:46:fc:d5 -> ff:ff:ff:ff:ff:ff ARP Who has 10.33.101.2? Tell 10.33.101.3
```

```
18:66:da:46:72:3b -> 12:66:da:46:fc:d5 ARP 10.33.101.2 is at 18:66:da:46:72:3b
```

Cette information n'est pas très utile si aucun paquet IP (ou assimilé) n'est échangé. Le protocole ICMP permet de montrer le mécanisme complet.

Rappel succin ICMP

Le protocole ICMP (*Internet Control Message Protocol*) est utilisé pour gérer le protocole Internet. Il est donc très maladroît de l'interdire par un firewall.

Parmi les messages possibles, il y a le couple *Demande d'écho* et *Réponse d'écho*. Ce couple permet de valider la vivacité et la connectivité d'un ordinateur distant. La demande d'écho peut être interdite par un firewall, mais cela risque de rendre les diagnostics plus compliqués.

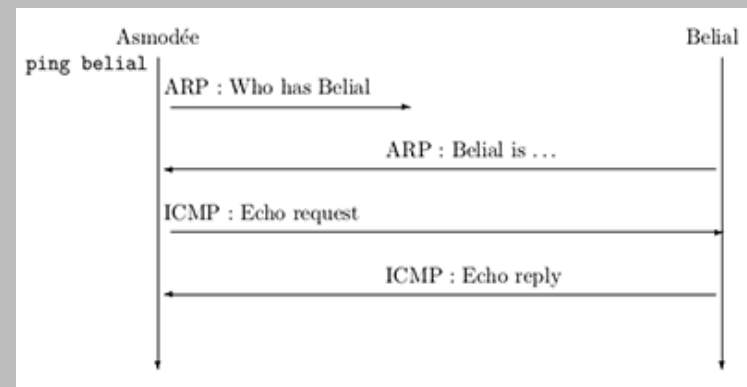
Un hôte souhaite tester la connectivité d'un ordinateur distant. Il va demander un écho (commande ping). S'il ne connaît pas l'adresse Ethernet de la destination, il va envoyer la requête ARP et obtenir la réponse, puis initier le dialogue ICMP.

La machine distante va répondre rapidement au ping, car le premier dialogue ARP lui permet de connaître l'adresse Ethernet de l'initiateur. Il va ensuite effectuer une requête ARP gratuite (*gratuitous ARP*).

Cette requête est inutile pour le fonctionnement normal, mais permet de détecter des problèmes.

Fig. 2 : Chronogramme d'une connexion ICMP/ARP.

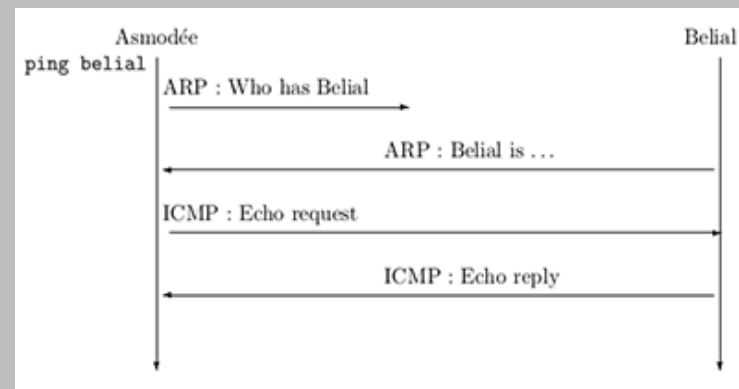
```
18:66:da:46:72:3b -> ff:ff:ff:ff:ff:ff ARP Who has 10.33.101.3? Tell 10.33.101.2
18:66:da:46:fc:d5 -> 18:66:da:46:72:3b ARP 42 10.33.101.3 is at 18:66:da:46:fc:d5
10.33.101.2 -> 10.33.101.3 ICMP 98 Echo (ping) request
10.33.101.3 -> 10.33.101.2 ICMP 98 Echo (ping) reply
18:66:da:46:fc:d5 -> 18:66:da:46:72:3b ARP Who has 10.33.101.2? Tell 10.33.101.3
18:66:da:46:72:3b -> 18:66:da:46:fc:d5 ARP 10.33.101.2 is at 18:66:da:46:72:3b
```



Si un hôte ne répond pas aux demandes d'écho ICMP, il devrait néanmoins répondre aux requêtes ARP.

Le comportement classique de nmap consiste à utiliser les demandes d'écho comme préalable aux autres interrogations, mais il peut aussi s'en passer et utiliser d'autres techniques pour détecter l'existence d'un hôte.

Sur le réseau local, il utilisera le protocole ARP.
À distance, il utilisera des tentatives UDP ou TCP.



Nmap peut donc être utilisé pour attaquer une victime, mais aussi pour détecter un ordinateur introduit subrepticement dans le réseau par un malfaissant. Il y a alors de bonnes chances pour que celui-ci bloque les demandes d'écho.

Le logiciel **arpwatch** permettra de détecter de nouveaux appareils inconnus que nmap pour analyser.

Arpwatch est un utilitaire qui permet de surveiller le réseau local a la recherche d'activité ARP

Il maintient une table de correspondance adresse IP/mac adress.

```
$ sudo apt install arpwatch
```

Éditer le fichier de configuration

```
$ sudo vim /etc/arpwatch.conf
```

Ajouter :

```
enp3s0 -a -n 192.168.1.0/24 -m adresse_email
```

enp3s0 = correspond a l'interface d'écoute
-a = actualise a la découverte d'une nouvelle IP dans la plage
-n = spécifie la plage et son masque de sous réseau.
-m = pour spécifier une adresse mail en sortie.

Redémarrer le service et le rendre automatique.

```
$ sudo systemctl restart arpwatch.service
```

```
$ sudo systemctl enable arpwatch.service
```

La BDD ou sont stockées les infos ce trouve sur /var/lib/arpwatch

```
# cat /var/lib/arpwatch/enp3s0.dat
```

```
08:00:27:aa:c5:4f 192.168.3.70 1494089126 vm-osticket enp3s0
```

```
xx:xx:xx:xx:xx:xx 192.168.3.72 1494090180 enp3s0
```

Pour visualiser dans le syslog

```
$ grep "new station" /var/log/syslog
```

```
May 6 18:44:55 lnx arpwatch: new station 192.168.3.70 08:00:27:aa:c5:4f enp5s0
```

```
May 6 19:03:00 lnx arpwatch: new station 192.168.3.72 xx:xx:xx:xx:xx:xx enp5s0
```


Demandez l'écho !

Une façon de détecter les hôtes consiste à envoyer une demande d'écho à chaque hôte. L'utilisation des pings de broadcast permet de demander une réponse à tous les hôtes sur le même réseau local. Cela fait plusieurs décennies que cette méthode ne fonctionne plus.

Pour envoyer un ping à chaque adresse, il est possible soit de faire une boucle en shell :

```
for i in {1..254} ;  
do  
    ping -c 1 10.1.2.$i  
done
```

soit d'utiliser des outils plus performants, comme **fping** :

```
fping -q -g -a 10.1.2.1/24
```

Du point de vue du réseau, c'est similaire, une demande d'écho est envoyée à chaque adresse, certaines répondent.

Avec fping, l'analyse des résultats est plus simple.

Ces outils sont efficaces, mais supposent que tout est conforme aux spécifications des protocoles Internet.

nmap, lui, essaie d'être plus efficace et peut s'adapter à des situations plus exotiques.

```
root@syssem:/home/syssem# fping -q -g -a 192.168.1.0/24
```

192.168.1.1

192.168.1.31

192.168.1.36

192.168.1.43

192.168.1.50

192.168.1.51

192.168.1.27

192.168.1.59

192.168.1.65

192.168.1.100

192.168.1.120

192.168.1.138

192.168.1.141

192.168.1.143

192.168.1.140

192.168.1.174

192.168.1.178

192.168.1.236

192.168.1.233

192.168.1.250

192.168.1.253

192.168.1.2

192.168.1.246

192.168.1.214

-sS(Scan TCP SYN)

Le scan SYN est celui par défaut et le plus populaire pour de bonnes raisons. Il peut être exécuté rapidement et scanner des milliers de ports par seconde sur un réseau rapide lorsqu'il n'est pas entravé par des pare-feux. Le scan SYN est relativement discret et furtif, vu qu'il ne termine jamais les connexions TCP. Il marche également contre toute pile respectant TCP, au lieu de dépendre des particularités environnementales spécifiques comme les scans Fin/Null/Xmas, Maimon ou Idle le sont. Il permet de plus une différenciation fiable entre les états ouvert, fermé et filtré.

Cette technique est souvent appelée le scan demi-ouvert (half-open scanning), car il n'établit pas pleinement la connexion TCP. Il envoie un paquet SYN et attend sa réponse, comme s'il voulait vraiment ouvrir une connexion. Une réponse SYN/ACK indique que le port est en écoute (ouvert), tandis qu'une RST (reset) indique le contraire. Si aucune réponse n'est reçue après plusieurs essais, le port est considéré comme étant filtré. Le port l'est également si un message d'erreur « unreachable ICMP (type 3, code 1, 2, 3, 9, 10 ou 13) » est reçu.

-sT(Scan TCP connect())

Le scan TCP connect() est le type de scan par défaut quand le SYN n'est pas utilisable. Tel est le cas lorsque l'utilisateur n'a pas les privilèges pour les paquets bruts (raw packets) ou lors d'un scan de réseaux IPv6. Plutôt que d'écrire des paquets bruts comme le font la plupart des autres types de scan, Nmap demande au système d'exploitation qui l'exécute d'établir une connexion au port de la machine cible grâce à l'appel système connect(). C'est le même appel système haut-niveau qui est appelé par les navigateurs Web, les clients P2P et la plupart des applications réseaux qui veulent établir une connexion. Cet appel fait partie de l'interface d'application connue sous le nom de « Berkeley Sockets API ». Au lieu de lire les réponses brutes sur le support physique, Nmap utilise cette application API pour obtenir l'état de chaque tentative de connexion.

Si le scan SYN est disponible, il vaut mieux l'utiliser. Nmap a bien moins de contrôles sur l'appel système haut niveau connect() que sur les paquets bruts, ce qui le rend moins efficace. L'appel système complète les connexions ouvertes sur les ports cibles au lieu de les annuler lorsque la connexion est à demie ouverte, comme le fait le scan SYN. Non seulement c'est plus long et demande plus de paquets pour obtenir la même information, mais de plus la probabilité que les cibles activent la connexion est plus grande. Un IDS décent le fera, mais la plupart des machines ne disposent pas de ce système d'alarme. De nombreux services sur les systèmes UNIX standards noteront cette connexion dans le journal, accompagné d'un message d'erreur sibyllin si Nmap ouvre puis referme la connexion sans n'envoyer aucune donnée. Les services réseaux les plus piteux risquent même de tomber en panne, mais c'est assez rare. Un administrateur qui verrait un tas de tentatives de connexions dans ses journaux en provenance d'une seule machine devrait se rendre compte qu'il a été scanné.

-sU(Scan UDP)

Même si les services les plus connus d'Internet sont basés sur le protocole TCP, les services UDP sont aussi largement utilisés. DNS, SNMP ou DHCP (ports 53, 161/162 et 67/68) sont les trois exemples les plus courants. Comme le scan UDP est généralement plus lent et plus difficile que TCP, certains auditeurs de sécurité les ignorent. C'est une erreur, car les services UDP exploitables sont courants et les attaquants eux ne les ignoreront pas. Par chance, Nmap peut aider à répertorier les ports UDP.

Le scan UDP est activé avec l'option -sU. Il peut être combiné avec un scan TCP, comme le scan SYN (-sS).

Le scan UDP envoie un en-tête UDP (sans données) à chaque port visé. Si un message ICMP « port unreachable (type 3, code 3) » est renvoyé, le port est alors fermé. Les autres messages d'erreur « unreachable ICMP (type 3, codes 1, 2, 9, 10, or 13) » rendront le port filtré. À l'occasion, il arrive qu'un service réponde par un paquet UDP, prouvant que le port est dans l'état ouvert. Si aucune réponse n'est renvoyée après plusieurs essais, le port est considéré comme étant ouvert|filtré. Cela signifie que le port peut être soit ouvert, soit qu'un dispositif de filtrage bloque les communications. Le scan de versions (-sV) peut être utilisé pour différencier les ports ouverts de ceux filtrés.

Une des grandes difficultés avec le scan UDP est de l'exécuter rapidement. Les ports ouverts et filtrés ne renvoient que rarement des réponses, laissant Nmap expirer son délai de retransmission au cas où les paquets se soient perdus. Les ports fermés posent encore un plus grand problème: ils renvoient normalement une erreur ICMP « port unreachable ». Mais à la différence des paquets RST renvoyés par les ports TCP fermés en réponse à un scan SYN ou à un connect(), de nombreux hôtes limitent par défaut la cadence d'émission de ces messages. Linux et Solaris étant particulièrement stricts à ce sujet. Par exemple, le kernel 2.4.20 limite cette cadence des destinations inaccessibles (« destination unreachable ») à un par seconde (cf.net/ipv4/icmp.c).

Nmap détecte cette limitation de fréquence et s'y ralentit conformément afin d'éviter de saturer le réseau avec des paquets inutiles que la machine cible rejettera. Malheureusement, une limitation à la Linux d'un paquet par seconde fera qu'un scan des 65 536 ports prendra plus de 18 heures. Les idées pour accélérer les scans UDP incluent le scan des cibles en parallèle, ne scanner que les ports les plus courants en premier, scanner derrière le pare-feu et utiliser l'option --host-timeout pour éviter les hôtes les plus lents

-sN; -sF; -sX (Scans TCP Null, FIN et Xmas)

Ces trois types de scans (d'autres sont possibles en utilisant l'option `--scanflags` décrite dans la section suivante) exploitent une subtile faille de la RFC TCP pour différencier les ports entre ouverts et fermés. La page 65 indique que « si le port [de destination] est dans l'état fermé... un segment ne contenant pas le drapeau RST provoque l'émission d'un paquet RST comme réponse. ». La page suivante indique que pour les paquets envoyés à des ports sans aucun des drapeaux SYN, RST ou ACK activés: « il est peut vraisemblable que cela arrive, mais si cela est le cas, il faut rejeter le segment. »

Pour les systèmes respectant ce texte de la RFC, chaque paquet ne contenant ni SYN, ni RST, ni ACK se voit renvoyé un RST si le port est fermé et aucune réponse si le port est ouvert. Tant qu'aucun de ces drapeaux n'est utilisé, toute combinaison des trois autres (FIN, PSH et URG) son valides. Nmap exploite cela avec les trois types de scans:

Scan Null (-sN)

N'active aucun des bits (les drapeaux de l'en-tête TCP vaut 0).

Scan FIN (-sF)

N'active que le bit FIN.

Scan Xmas (-sX)

Active les drapeaux FIN, PSH et URG, illuminant le paquet comme un arbre de Noël (NDT: la fracture cognitive entre la culture anglo-saxonne et française se ressent fortement dans cette traduction...).

-sN; -sF; -sX (Scans TCP Null, FIN et Xmas)

Ces trois types de scan ont exactement le même comportement, sauf pour les drapeaux TCP utilisés dans des paquets de tests (probes packets). Si un RST est reçu, le port est considéré comme étant fermé, tandis qu'une absence de réponse signifiera qu'il est dans l'état ouvert|filtré. Le port est marqué comme filtré si un message d'erreur ICMP « unreachable (type 3, code 1, 2, 3, 9, 10 ou 13) » est reçu.

L'avantage principal de ces types de scans est qu'ils peuvent furtivement traverser certains pare-feux ou routeurs filtrants sans état de connexion (non-statefull). Un autre avantage est qu'ils sont même un peu plus furtifs que le scan SYN. N'y comptez pas trop dessus cependant -- la plupart des IDS modernes sont configurés pour les détecter. L'inconvénient majeur est que tous les systèmes ne respectent pas la RFC 793 à la lettre. Plusieurs systèmes renvoient des RST aux paquets quelque soit l'état du port de destination, qu'il soit ouvert ou pas. Ceci fait que tous les ports sont considérés comme fermé. Les plus connus des systèmes qui ont ce comportement sont Microsoft Windows, plusieurs équipements Cisco, BSDI et IBM OS/400. Ce type de scan fonctionne cependant très bien contre la plupart des systèmes basés sur UNIX. Un autre désagrément de ce type de scan est qu'ils ne peuvent pas distinguer les ports ouverts de certains autres qui sont filtrés, vous laissant face à un laconique ouvert|filtré.

-sA(Scan TCP ACK)

Ce type de scan est différent des autres abordés jusqu'ici, dans le sens où ils ne peuvent pas déterminer si un port est ouvert(ni même ouvert|filtré). Il est utilisé pour établir les règles des pare-feux, déterminant s'ils sont avec ou sans états (statefull/stateless) et quels ports sont filtrés.

Le scan ACK n'active que le drapeau ACK des paquets (à moins que vous n'utilisiez l'option --scanflags). Les systèmes non-filtrés réagissent en retournant un paquet RST. Nmap considère alors le port comme non-filtré, signifiant qu'il est accessible avec un paquet ACK, mais sans savoir s'il est réellement ouvert ou fermé. Les ports qui ne répondent pas ou renvoient certains messages d'erreur ICMP (type 3, code 1, 2, 3, 9, 10, ou 13), sont considérés comme filtrés.

Le scan de fenêtre TCP est exactement le même que le scan ACK à la différence près qu'il exploite un détail de l'implémentation de certains systèmes pour identifier les ports fermés des autres, au lieu de toujours afficher non-filtré lorsqu'un RST est renvoyé. Sur certains systèmes, les ports ouverts utilisent une taille de fenêtre TCP positive (même pour les paquets RST), tandis que les ports fermés ont une fenêtre de taille nulle. Ainsi, au lieu de toujours afficher non-filtré lorsqu'un RST est reçu, le scan de fenêtre indique que le port est ouvert ou fermé selon que la taille de fenêtre TCP de ce paquet RST est respectivement positive ou nulle.

Ce scan repose sur un détail d'implémentation d'une minorité de systèmes Internet, vous ne pouvez donc pas toujours vous y fier. Les systèmes qui ne le supportent pas vont certainement se voir considérés leurs ports comme fermés. Bien sûr, il se peut que la machine n'ait effectivement aucun port ouvert. Si la plupart des ports scannés sont fermés mais que quelques-uns courants, comme le 22, 25 ou le 53, sont filtrés, le système est vraisemblablement prédisposé à ce type de scan. Quelquefois, les systèmes ont le comportement exactement inverse. Si votre scan indique que 1 000 ports sont ouverts et que 3 seulement sont fermés ou filtrés, ces trois derniers sont certainement ceux qui sont ouverts.

-sM(Scan TCP Maimon)

Le scan Maimon est nommé ainsi d'après celui qui l'a découvert, Uriel Maimon. Il a décrit cette technique dans le numéro 49 de Phrack Magazine (Novembre 1996). Nmap, qui inclut cette technique, a été publié deux numéros plus tard. Cette technique est la même que les scans NULL, FIN et Xmas, à la différence près que le paquet de test est ici un FIN/ACK. Conformément à la RFC 793 (TCP), un paquet RST devrait être renvoyé comme réponse à un tel paquet, et ce, que le port soit ouvert ou non. Uriel a cependant remarqué que de nombreux systèmes basés sur BSD rejettent tout bonnement le paquet si le port est ouvert.

-sM(Scan TCP Maimon)

Le scan Maimon est nommé ainsi d'après celui qui l'a découvert, Uriel Maimon. Il a décrit cette technique dans le numéro 49 de Phrack Magazine (Novembre 1996). Nmap, qui inclut cette technique, a été publié deux numéros plus tard. Cette technique est la même que les scans NULL, FIN et Xmas, à la différence près que le paquet de test est ici un FIN/ACK. Conformément à la RFC 793 (TCP), un paquet RST devrait être renvoyé comme réponse à un tel paquet, et ce, que le port soit ouvert ou non. Uriel a cependant remarqué que de nombreux systèmes basés sur BSD rejettent tout bonnement le paquet si le port est ouvert.

Toutes les options sur <https://nmap.org/man/fr/man-nse.html>

Nmap local

Sur un réseau local, il n'y a pas besoin de routeur. Que ce soit pour utiliser IP ou ICMP, il faut obtenir l'adresse Ethernet.

Pour cela, il faut émettre une requête ARP. Donc, si nous listons les adresses et que nous regardons ce qui passe sur le réseau, voici ce que nous dit nmap :

nmap -sn 10.33.101.3

Starting Nmap 7.80 (<https://nmap.org>) at 2021-11-03 11:58 CET

Nmap scan report for jack (10.33.101.3)

Host is up (0.00049s latency).

MAC Address: 18:66:DA:46:FC:D5 (Dell)

Nmap done: 1 IP address (1 host up) scanned in 0.09 seconds

Et la capture réseau :

18:66:da:46:72:3b -> ff:ff:ff:ff:ff:ff ARP 60 Who has 10.33.101.3? Tell 10.33.101.2

18:66:da:46:fc:d5 -> 18:66:da:46:72:3b ARP 42 10.33.101.3 is at 18:66:da:46:fc:d5

Par contre, si un utilisateur non privilégié utilise la même commande, avec le même résultat apparent, voici la capture :

18:66:da:46:72:3b -> ff:ff:ff:ff:ff:ff ARP 60 Who has 10.33.101.3? Tell 10.33.101.2

18:66:da:46:fc:d5 -> 18:66:da:46:72:3b ARP 42 10.33.101.3 is at 18:66:da:46:fc:d5

10.33.101.2 -> 10.33.101.3 TCP 74 33464 -> 80 [SYN]

10.33.101.2 -> 10.33.101.3 TCP 74 59442 -> 443 [SYN]

10.33.101.3 -> 10.33.101.2 TCP 54 80 -> 33464 [RST, ACK]

10.33.101.3 -> 10.33.101.2 TCP 54 443 -> 59442 [RST, ACK]

L'utilisateur classique ne peut pas faire de requête ARP ni capturer les paquets réseaux.

Donc nmap tente d'ouvrir des connexions TCP sur les ports 80 et 443.

Soit les ports ne sont pas filtrés (donc ouverts ou fermés) et nmap obtient une réponse (ici, les ports sont fermés), soit ils sont filtrés (pas de réponse) et nmap ne peut pas conclure.

Nous commençons à voir que pour un réseau normal, toutes les commandes permettent de fournir une réponse correcte, mais que si certaines parties sont obscurcies, alors il faut savoir comment poser la bonne question pour obtenir une réponse exacte.

Ainsi, en laissant l'ordinateur allumé, mais en filtrant les ports 80 et 443, nmap répond :

```
nmap -sn jack
Starting Nmap 7.80 ( https://nmap.org )
Note: Host seems down.
```

En bon français, l'hôte *semble* éteint.

Par contre, la commande **ip neighbour** liste l'hôte qui a répondu à la requête ARP.

La même commande en tant qu'administrateur exploite directement le protocole ARP et fournit la bonne réponse.

Nmap distant

Si nous entrons la même commande, mais depuis un autre réseau, la capture est encore différente selon l'utilisateur. L'utilisateur normal fait des requêtes vers les ports 80 et 443, mais pas de requête ICMP.

L'administrateur fait des requêtes différentes :

```
10.30.3.163 -> 10.33.101.3 ICMP 60 Echo (ping) request id=0x7408, seq=0/0, ttl=58
10.30.3.163 -> 10.33.101.3 TCP 60 37233 -> 443 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
10.30.3.163 -> 10.33.101.3 ICMP 60 Timestamp request id=0x50bb, seq=0/0, ttl=51
10.30.3.163 -> 10.33.101.3 TCP 60 37233 -> 80 [ACK] Seq=1 Ack=1 Win=1024 Len=0
10.33.101.3 -> 10.30.3.163 ICMP 42 Echo (ping) reply id=0x7408, seq=0/0, ttl=64 (request in 1)
10.33.101.3 -> 10.30.3.163 TCP 54 443 -> 37233 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
10.33.101.3 -> 10.30.3.163 ICMP 54 Timestamp reply id=0x50bb, seq=0/0, ttl=64
10.33.101.3 -> 10.30.3.163 TCP 54 80 -> 37233 [RST] Seq=1 Win=0 Len=0
```

Nous voyons plusieurs demandes simultanées :

- Une demande d'écho ICMP ;
- Une demande de temps ICMP ;
- Un début de connexion TCP sur le port 443 ;
- Un paquet erroné vers le port 80.

Il n'y pas de filtrage, donc les réponses ICMP arrivent et le noyau du destinataire répond par des RST aux questions TCP. Nous voyons ici des stratégies de nmap pour contourner des erreurs de fabrication ou de configuration.

Le paquet ACK envoyé vers le port 80 permet de contourner certains firewalls qui ne filtrent que le premier paquet (SYN), mais pas les suivants. Nous voyons que nmap peut aussi tester le fonctionnement des firewall de type boîte noire.

Cherchez les services

Chercher les ports ouverts et identifier les services.

1 - interrogation TCP :

nmap -p -10.33.101.2

Starting Nmap 7.80 (<https://nmap.org>) at 2021-11-04 09:49 CET

Nmap scan report for joe (10.33.101.2)

Host is up (0.000085s latency).

Not shown: 65530 closed ports

PORT STATE SERVICE

22/tcp open ssh

23/tcp open telnet

53/tcp open domain

80/tcp open http

111/tcp open rpcbind

MAC Address: 18:66:DA:46:72:3B (Dell)

Nmap done: 1 IP address (1 host up) scanned in 0.62 seconds

Cherchez les services

Utilisation de netcat pour créer un serveur temporaire sur le port telnetd :

```
# netcat -l -p 23
```

Puis lançons l'interrogation par nmap :

```
# nmap -p- 10.33.101.3
PORT      STATE SERVICE
23/tcp    open  telnet
```

nmap identifie le port ouvert comme étant celui du service telnet. Voici la capture réseau :

```
10.33.101.2 -> 10.33.101.3 TCP 60 46083 -> 23 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
10.33.101.3 -> 10.33.101.2 TCP 58 23 -> 46083 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
10.33.101.2 -> 10.33.101.3 TCP 60 46083 -> 23 [RST] Seq=1 Win=0 Len=0
```

nmap initie la communication TCP (drapeau SYN)

→ la pile TCP distante répond (drapeaux SYN/ACK)

la machine initiatrice répond par un drapeau RST.

Si nmap est lancé avec les privilèges administrateur, il ne demande pas au noyau d'ouvrir une connexion, mais crée directement le paquet.

Le noyau n'étant pas informé du premier paquet, il répond directement par un RST.

Si nmap n'a pas les privilèges administrateur, alors il demande une connexion TCP qui s'établit. Les trois paquets de la phase de connexion apparaissent et nmap termine ensuite la communication. La capture montre quatre paquets.

Identifiez les services ouverts

scan vers une Debian fraîche en testant uniquement les 1000 les plus courants.

```
nmap -sV -A 10.33.101.2
```

```
Host is up (0.00046s latency).
```

```
Not shown: 995 closed ports
```

```
PORT      STATE SERVICE VERSION
```

```
22/tcp open  ssh      OpenSSH 8.4p1 Debian 5 (protocol 2.0)
```

```
23/tcp open  telnet   Linux telnetd
```

```
53/tcp open  domain  dnsmasq 2.85
```

```
| dns-nsid:
```

```
|_ bind.version: dnsmasq-2.85
```

```
80/tcp open  http     lighttpd 1.4.59
```

```
|_ http-server-header: lighttpd/1.4.59
```

```
|_ http-title: 403 Forbidden
```

```
111/tcp open  rpcbind  2-4 (RPC #100000)
```

```
| rpcinfo:
```

	program	version	port/proto	service
	100000	2,3,4	111/tcp	rpcbind
	100000	2,3,4	111/udp	rpcbind
	100000	3,4	111/tcp6	rpcbind
_	100000	3,4	111/udp6	rpcbind

Network Distance: 1 hop

Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Cette recherche a utilisé 2771 paquets. La plupart concernent une demande de connexion vers un port et la réponse de ce port (réponse ou *reset*).

Pour les ports ouverts, nmap tente d'autres actions. Ainsi, l'interrogation du port SSH consomme 300 paquets

Identifiez les services ouverts

scan vers une Debian fraîche en testant uniquement les 1000 les plus courants.

```
nmap -sV -A 10.33.101.2
```

```
Host is up (0.00046s latency).
```

```
Not shown: 995 closed ports
```

```
PORT      STATE SERVICE VERSION
```

```
22/tcp open  ssh      OpenSSH 8.4p1 Debian 5 (protocol 2.0)
```

```
23/tcp open  telnet   Linux telnetd
```

```
53/tcp open  domain   dnsmasq 2.85
```

```
| dns-nsid:
```

```
|_ bind.version: dnsmasq-2.85
```

```
80/tcp open  http     lighttpd 1.4.59
```

```
|_ http-server-header: lighttpd/1.4.59
```

```
|_ http-title: 403 Forbidden
```

```
111/tcp open  rpcbind  2-4 (RPC #100000)
```

```
| rpcinfo:
```

	program	version	port/proto	service
	100000	2,3,4	111/tcp	rpcbind
	100000	2,3,4	111/udp	rpcbind
	100000	3,4	111/tcp6	rpcbind
_	100000	3,4	111/udp6	rpcbind

Network Distance: 1 hop

Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Cette recherche a utilisé 2771 paquets. La plupart concernent une demande de connexion vers un port et la réponse de ce port (réponse ou *reset*).

Pour les ports ouverts, nmap tente d'autres actions. Ainsi, l'interrogation du port SSH consomme 300 paquets

<https://nmap.org/man/fr/man-port-scanning-techniques.html>

```
root@syssem:/home/syssem# nmap -sV -A -p- 192.168.1.141
```

Starting Nmap 7.80 (<https://nmap.org>) at 2022-04-06 10:38 CEST

Nmap scan report for syssem (192.168.1.141)

Host is up (0.00011s latency).

Not shown: 65531 closed ports

PORT	STATE	SERVICE	VERSION
------	-------	---------	---------

22/tcp	open	ssh	OpenSSH 8.2p1 Ubuntu 4ubuntu0.4 (Ubuntu Linux; protocol 2.0)
--------	------	-----	--

1716/tcp	open	xmsg?	
----------	------	-------	--

3389/tcp	open	ms-wbt-server	xrdp
----------	------	---------------	------

7070/tcp	open	ssl/realserver?	
----------	------	-----------------	--

|_ssl-date: TLS randomness does not represent time

No exact OS matches for host (If you know what OS is running on it, see <https://nmap.org/submit/>).

TCP/IP fingerprint:

OS:SCAN(V=7.80%E=4%D=4/6%OT=22%CT=1%CU=43183%PV=Y%DS=0%DC=L%G=Y%TM=624D52BC

OS:%P=x86_64-pc-linux-gnu)SEQ(SP=10A%GCD=1%ISR=108%TI=Z%CI=Z%II=I%TS=A)OPS(

OS:O1=MFFD7ST11NW7%O2=MFFD7ST11NW7%O3=MFFD7NNT11NW7%O4=MFFD7ST11NW7%O5=MFFD

OS:7ST11NW7%O6=MFFD7ST11)WIN(W1=FFCB%W2=FFCB%W3=FFCB%W4=FFCB%W5=FFCB%W6=FFC

OS:B)ECN(R=Y%DF=Y%T=40%W=FFD7%O=MFFD7NNSNW7%CC=Y%Q=)T1(R=Y%DF=Y%T=40%S=O%A=

OS:S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q

OS:)=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)T6(R=Y%DF=Y%T=40%W=0%S=A

OS:%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)U1(R=Y

OS:%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N%T

OS:=40%CD=S)

Network Distance: 0 hops

Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at <https://nmap.org/submit/> .

Nmap done: 1 IP address (1 host up) scanned in 302.80 seconds

Pentest

Qu'est ce qu'un Pentest ?

Lors d'un Pentest, en anglais « Penetration Test » et en français « test d'intrusion », les systèmes ou les réseaux informatiques sont soumis à un test complet visant à déterminer la sensibilité aux attaques. Un pentest utilise des méthodes et techniques utilisées par de vrais attaquants ou pirates.

À l'aide d'un test de pénétration, souvent appelé pentest, les experts en informatique utilisent des attaques ciblées pour détecter la sensibilité des réseaux ou des systèmes informatiques aux tentatives de cambriolage et de manipulation. Ils utilisent des méthodes et techniques similaires à celles utilisées par les pirates informatiques ou les pirates pour pénétrer dans un système sans autorisation.

Un pentest peut être utilisé pour découvrir des faiblesses et mieux évaluer les risques potentiels. Au cours du test de pénétration complet, un enregistrement détaillé de toutes les mesures mises en œuvre est effectué. Un rapport final identifie les vulnérabilités identifiées et les solutions pour améliorer les niveaux de sécurité informatique. L'élimination des vulnérabilités et l'exécution de mesures de renforcement informatique ne font pas partie du test d'intrusion. La portée des tests est basée sur le potentiel de risque respectif d'un système, d'une application ou d'un réseau. Les systèmes exposés à des risques élevés, tels que les serveurs Web accessibles au public, sont généralement soumis à des tests plus approfondis que les applications internes sans grande pertinence systémique.

Les ressources de type "must have" pour apprendre les méthodes :

- <https://book.hacktricks.xyz/>
- <https://github.com/swisskyrepo/PayloadsAllTheThings/>

Connaître les sujets : XSS, SQLI, CSRF, SSRF, SSTI, command injection, rien que sur le périmètre web

HackTheBox / Root-Me (Réaliste) ne sont intéressants qu'après avoir compris un certain nombre de concepts d'attaques comme la Kill Chain avec phase de reconnaissance, vulnérabilité, obtention d'un accès (reverse shell, bind shell, ...), privesc, ...

Kali reste le top mais il y a d'autres distributions telles que :

- Parrot (<https://www.parrotsec.org/>)
- Backbox (<https://backbox.org/>)
- BlackArch (<https://blackarch.org/>)
- ...

Root-Me est intéressant pour apprendre les méthodes d'attaques via les différentes catégories représentées :

- web-server, web-client, app-script, network, crypto, app-sys, forensic, ...

et aussi <https://pix.fr/les-tests/>

Quelques sites pour s'exercer au pentest :

- RootMe

Très bien pour apprendre, des challenges de différents niveaux sur différentes thématiques, mais ce n'est pas du pentest. dans la partie CTF All The Day toutes les machines de la catégorie "Réaliste" ainsi que quasiment toutes les VMs de Vulnhub ce qui permet de ne pas les installer sur son poste !! ;-)

- HackTheBox

Très bien également, il y a des machines "faciles", y compris Windows, elles sont accessibles par VPN, mais pour un débutant, ça peut être déroutant. Il peut y avoir des indices donnés dans les forums ou sur des canaux Discord, mais pas de solution si on est coincé.

- <https://www.vulnhub.com>, il y a plein de VM à attaquer, de différents niveaux. A la différence de HTB, il faut l'installer dans Virtualbox. L'avantage pour un débutant c'est que des writeups (solutions) sont disponibles. Par exemple ici : <https://www.hackingarticles.in/ctf-challenges-walkthrough/>. Pour commencer, on peut très bien suivre des writeups comme des tutoriels pour s'approprier la méthodologie de pentest. (Joël GROUFFAUD)

<https://www.vulnhub.com/>

Le top. Tu choisis la difficulté, tu télécharges une VM, tu as ta kali à côté et hop
un site d'exercices assez sympa pour jouer ses gammes.. (des VMs à hacker)

<https://tryhackme.com/> si l'anglais ne le rebute pas...

Sur Kali, le cours d'Offensive Security est vraiment bien fait et gratuit : <https://kali.training/>
Raphaël Hertzog, développeur Debian y a contribué et ce cours est une bonne introduction à Linux.

Quelques sites pour s'exercer au pentest :

<https://play.picoctf.org>

Pour démarrer ça permet de faire de petits challenges sur un peu tout et se familiariser avec le concept, sans avoir besoin de grand chose. il y a même les shells online.

Activez l'IP forwarding

```
# echo 1 > /proc/sys/net/ipv4/ip_forward
```

Principe et fonctionnement

NetFilter est un module noyau qui se manipule à l'aide de la commande iptables. Il dispose de plusieurs tables (modes) :

- filter : filtrage de paquets.
- nat : translation d'adresses.
- mangle : altération de l'entête des paquets.
- raw : marquage de paquets.
- security : contrôle d'accès mandataire

DMZ

Une DMZ (demilitarized zone) est une zone particulière d'un réseau privé qui héberge des services publics (serveur HTTP, FTP, DNS, etc.). Une DMZ répond à un règlement de connexions strict :

1. Le trafic externe $\leftrightarrow$ DMZ est autorisé.
2. Le trafic interne $\rightarrow$ DMZ est autorisé.
3. Le trafic interne $\leftarrow$ DMZ est interdit

Activez l'IP forwarding

```
# echo 1 > /proc/sys/net/ipv4/ip_forward
```

Principe et fonctionnement

NetFilter est un module noyau qui se manipule à l'aide de la commande iptables. Il dispose de plusieurs tables (modes) :

- filter : filtrage de paquets.
- nat : translation d'adresses.
- mangle : altération de l'entête des paquets.
- raw : marquage de paquets.
- security : contrôle d'accès mandataire

DMZ

Une DMZ (demilitarized zone) est une zone particulière d'un réseau privé qui héberge des services publics (serveur HTTP, FTP, DNS, etc.). Une DMZ répond à un règlement de connexions strict :

1. Le trafic externe $\leftrightarrow$ DMZ est autorisé.
2. Le trafic interne $\rightarrow$ DMZ est autorisé.
3. Le trafic interne $\leftarrow$ DMZ est interdit

Usages

Usage général :

iptables {--table|-t} <table> [<action> <zone>] [ordres...]

Usages courants :

- . Voir table : iptables -t <table> {-L|--list} [-n|--line-numbers]
- . Vider table : iptables -t <table> {-F|--flush}
- . Règle défaut : iptables -t <table> {-P|--policy} <zone> [ordres...]
- . Ajouter règle : iptables -t <table> {-A|--append} <zone> <tests> {-j|--jump} <action>

Tests :

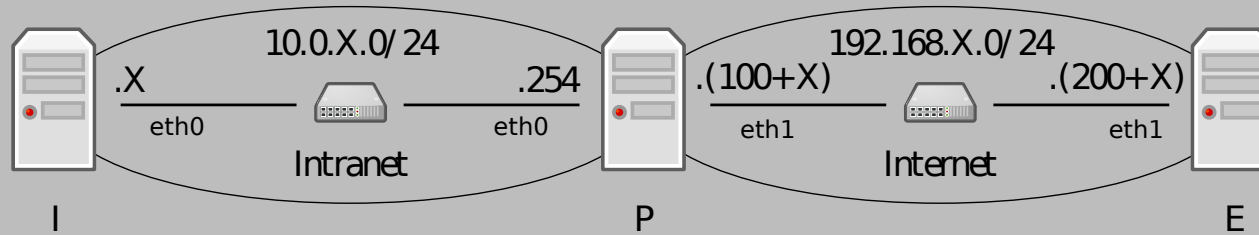
- . {-d|--destination} {<@IP>|<@IP réseau>}
- . {-s|--source} {<@IP>|<@IP réseau>}
- . {-i|--in-interface} <iface>
- . {-o|--out-interface} <iface>
- . {-p|--protocol} <protocole>
- . {--dport|--destination-port} <port>
- . {--sport|--source-port} <port>
- m state --state <état>

Td Architecture des réseaux : NAT

NAT (Network Address Translation) permet de faire correspondre des adresses IP privées (RFC 1918) d'un intranet à des adresses externes publiques et donc routables sur internet. La mise en oeuvre sur linux passe par la table nat des iptables avec plusieurs déclinaisons du mécanisme de réécriture des adresses IP et des ports dans les paquets.

Pour rappel, les plages d'adresses IPv4 privées définies dans la RFC 1918 sont les suivantes :

10/8
172.16/12
192.168/16



Dans cette situation, figurent trois hôtes : E (Externe), I (Interne) et P (Passerelle). Le réseau 192.168.X.0/24 est considéré comme étant le réseau public.

Effacer tous les paramètres

```
iptables -F  
iptables -t filter -F  
iptables -t nat -F  
iptables -t mangle -F
```

Autoriser le Loopback

```
iptables -A INPUT -i lo -j ACCEPT  
iptables -A OUTPUT -o lo -j ACCEPT
```

Ne pas casser les connexions déjà établies

```
iptables -t filter -A INPUT -m state --state RELATED,ESTABLISHED -j ACCEPT  
iptables -t filter -A OUTPUT -m state --state RELATED,ESTABLISHED -j ACCEPT
```

PING (ICMP)

```
iptables -t filter -A INPUT -p icmp -j ACCEPT  
iptables -t filter -A OUTPUT -p icmp -j ACCEPT
```

Serveur MAIL SMTP:25

```
iptables -t filter -A INPUT -p tcp --dport 25 -j ACCEPT  
iptables -t filter -A OUTPUT -p tcp --dport 25 -j ACCEPT  
iptables -A OUTPUT -p tcp --dport 587 -j ACCEPT
```

Serveur MAIL POP3:110

```
iptables -t filter -A INPUT -p tcp --dport 110 -j ACCEPT  
iptables -t filter -A OUTPUT -p tcp --dport 110 -j ACCEPT
```

Serveur MAIL IMAP:143

```
iptables -t filter -A INPUT -p tcp --dport 143 -j ACCEPT  
iptables -t filter -A OUTPUT -p tcp --dport 143 -j ACCEPT
```

Serveur MAIL POP3S:995

```
iptables -t filter -A INPUT -p tcp --dport 995 -j ACCEPT  
iptables -t filter -A OUTPUT -p tcp --dport 995 -j ACCEPT
```

NTP

```
iptables -t filter -A OUTPUT -p udp --dport 123 -j ACCEPT  
iptables -t filter -A INPUT -p udp --dport 123 -j ACCEPT
```

DNS In/Out

```
iptables -t filter -A INPUT -p tcp --dport 53 -j ACCEPT
iptables -t filter -A INPUT -p udp --dport 53 -j ACCEPT
iptables -t filter -A OUTPUT -p tcp --dport 53 -j ACCEPT
iptables -t filter -A OUTPUT -p udp --dport 53 -j ACCEPT
```

#Samba

```
iptables -A INPUT -p tcp --dport 135 -j ACCEPT
iptables -A OUTPUT -p tcp --dport 135 -j ACCEPT
iptables -A INPUT -p udp --dport 135 -j ACCEPT
iptables -A OUTPUT -p udp --dport 135 -j ACCEPT
iptables -A INPUT -p tcp --dport 137 -j ACCEPT
iptables -A OUTPUT -p tcp --dport 137 -j ACCEPT
iptables -A INPUT -p udp --dport 137 -j ACCEPT
iptables -A OUTPUT -p udp --dport 137 -j ACCEPT
iptables -A INPUT -p udp --dport 138 -j ACCEPT
iptables -A OUTPUT -p udp --dport 138 -j ACCEPT
iptables -A INPUT -p tcp --dport 139 -j ACCEPT
iptables -A OUTPUT -p tcp --dport 139 -j ACCEPT
iptables -A INPUT -p tcp --dport 445 -j ACCEPT
iptables -A OUTPUT -p tcp --dport 445 -j ACCEPT
iptables -A INPUT -p udp --dport 445 -j ACCEPT
iptables -A OUTPUT -p udp --dport 445 -j ACCEPT
```

#Whois

```
iptables -A INPUT -p tcp --dport 43 -j ACCEPT  
iptables -A OUTPUT -p tcp --dport 43 -j ACCEPT
```

#DDOS interdit

```
iptables -A FORWARD -p tcp --syn -m limit --limit 1/second -j ACCEPT
```

#Nolp

```
iptables -A INPUT -p tcp --dport 8245 -j ACCEPT  
iptables -A INPUT -p udp --dport 8245 -j ACCEPT  
iptables -A OUTPUT -p tcp --dport 8245 -j ACCEPT  
iptables -A OUTPUT -p udp --dport 8245 -j ACCEPT
```

#Transmission

```
iptables -A OUTPUT -p tcp --dport 9091 -j ACCEPT  
iptables -A INPUT -p tcp --dport 9091 -j ACCEPT  
iptables -A INPUT -p tcp --dport 51413 -j ACCEPT  
iptables -A OUTPUT -p tcp --dport 51413 -j ACCEPT
```

#Monit

```
iptables -A INPUT -p tcp --dport 2812 -j ACCEPT  
iptables -A INPUT -p udp --dport 2812 -j ACCEPT  
iptables -A OUTPUT -p tcp --dport 2812 -j ACCEPT  
iptables -A OUTPUT -p udp --dport 2812 -j ACCEPT
```


#Squid

```
iptables -A INPUT -p tcp --dport 3128 -j ACCEPT  
iptables -A INPUT -p udp --dport 3128 -j ACCEPT  
iptables -A OUTPUT -p tcp --dport 3128 -j ACCEPT  
iptables -A OUTPUT -p udp --dport 3128 -j ACCEPT
```

#DHCP

```
iptables -A INPUT -p tcp --dport 10000 -j ACCEPT  
iptables -A OUTPUT -p tcp --dport 10000 -j ACCEPT
```

#OpenVPN

```
iptables -A INPUT -p tcp --dport 1194 -j ACCEPT  
iptables -A INPUT -p udp --dport 1194 -j ACCEPT  
iptables -A OUTPUT -p tcp --dport 1194 -j ACCEPT  
iptables -A OUTPUT -p udp --dport 1194 -j ACCEPT
```

#autoriser les connexions au port 21 (ftp)

```
iptables -A INPUT -p tcp --dport 21 -j ACCEPT
```

```
# Rejeter tout le reste
iptables -A INPUT -j DROP
echo "Filtrages [OK]"
```

POLITIQUES

```
# Trafic entrants bloqués
iptables -P INPUT DROP
```

```
# Trafic forwardés bloqués
iptables -P FORWARD DROP
```

```
# Trafic sortants bloqués
iptables -P OUTPUT DROP
```

```
# Supprime tous les filtres
iptables -F
iptables -t filter -F
iptables -t nat -F
iptables -t mangle -F
```

Attribut une politiques "ACCEPT" aux tables

```
iptables -P INPUT ACCEPT  
iptables -P FORWARD ACCEPT  
iptables -P OUTPUT ACCEPT
```

```
iptables -t filter -P INPUT ACCEPT  
iptables -t filter -P FORWARD ACCEPT  
iptables -t filter -P OUTPUT ACCEPT
```

```
iptables -t nat -P PREROUTING ACCEPT  
iptables -t nat -P POSTROUTING ACCEPT  
iptables -t nat -P OUTPUT ACCEPT
```

```
iptables -t mangle -P PREROUTING ACCEPT  
iptables -t mangle -P INPUT ACCEPT  
iptables -t mangle -P FORWARD ACCEPT  
iptables -t mangle -P OUTPUT ACCEPT  
iptables -t mangle -P POSTROUTING ACCEPT
```